

Copilot für Admins

Microsoft 365 Copilot sicher, kontrolliert und datenschutzkonform in Unternehmen integrieren

Schulungsunterlage für einen Schultag | Stand: 12. Juni 2026

Kernaussage: Copilot ist nicht automatisch ein Datenschutzproblem. Das eigentliche Risiko entsteht durch schlechte Berechtigungen, alte Daten, unkontrollierte externe Freigaben, ungeprüfte Agents, Websuche und Meeting-Transkripte. Copilot schafft keine neuen Rechte, aber er macht schlechte Rechte sehr schnell sichtbar. [1][5]

Punkt	Beschreibung
Zielgruppe	Microsoft 365 Admins, IT-Leitung, Datenschutz/Compliance, Security-Verantwortliche, Power Platform- und Copilot-Verantwortliche
Dauer	1 Schultag, ca. 09:00 bis 17:00 Uhr, inklusive Übungen, Checklisten und Abschlussfragen
Vorkenntnisse	Grundlagen Microsoft 365, SharePoint, Teams, Entra ID. Purview-Grundlagen sind hilfreich.
Ergebnis	Teilnehmende können Copilot kontrolliert einführen, absichern, überwachen und ein Governance-Modell definieren.

Inhaltsübersicht

- 1. Tagesagenda und Lernziele
- 2. Architektur, Datenflüsse und das echte Risiko
- 3. Voraussetzungen: Lizenzen, Apps, Identität und Rollen
- 4. Datenschutz- und Sicherheitsprinzipien
- 5. Datenbasis absichern: SharePoint, OneDrive, Teams und Exchange
- 6. Microsoft Purview: Labels, DLP, Audit, Retention und eDiscovery
- 7. Copilot Control System und Admin-Konfigurationen
- 8. Teams, Websuche, Copilot Chat und Agents steuern
- 9. Praxis-Labs für den Schultag
- 10. Rollout, Betrieb und Governance
- 11. Abschlussfragen, Vorlagen und Quellen

Hinweis: Pfadangaben und Funktionsnamen sind produktnah, müssen aber im jeweiligen Tenant geprüft werden. Copilot-Adminfunktionen ändern sich häufig.

1. Tagesagenda und Lernziele

Die Schulung ist als kompletter Admin-Tag konzipiert. Sie kombiniert Einordnung, Konfiguration, Datenschutz, Governance und praktische Übungen.

Zeit	Modul	Inhalt	Ergebnis
09:00–09:30	Einordnung	Warum Copilot Governance braucht; Nutzen, Risiken, Verantwortlichkeiten	Gemeinsames Zielbild
09:30–10:15	Architektur & Datenschutz	Microsoft Graph, Berechtigungen, Prompts, Antworten, Service Boundary, Enterprise Data Protection	Datenflüsse verstanden
10:30–11:30	Voraussetzungen	Lizenzen, Updatekanäle, Entra ID, Exchange Online, OneDrive, Adminrollen	Preflight-Checkliste
11:30–12:30	Datenbasis absichern	SharePoint/OneDrive/Teams, externe Freigaben, Oversharing, SAM, Restricted SharePoint Search	Risikobild für Inhalte
13:15–14:30	Purview & Compliance	Sensitivity Labels, DLP für Copilot, Audit, Retention, eDiscovery, Communication Compliance	Sicherheitskontrollen definiert
14:30–15:15	Copilot Control System	Admin Center, Websuche, Teams-Richtlinien, Copilot Chat, Agents	Konfigurationsmatrix
15:30–16:30	Praxis-Labs	Testbenutzer, SharePoint-Testdaten, DLP-Regel, Teams-Policy, Agent-Freigabe	Umsetzbare Admin-Schritte
16:30–17:00	Betrieb & Abschluss	Rollout-Plan, Betriebsmodell, Monitoring, Prüfungsfragen	Go-live-Entscheidung

Lernziele

- Copilot-Datenflüsse und Berechtigungsmodell erklären können.
- Mindestvoraussetzungen für Microsoft 365 Copilot und Copilot Chat prüfen können.
- Risiken durch überbreite SharePoint-, Teams- und OneDrive-Berechtigungen erkennen und reduzieren.
- Microsoft Purview für Labels, DLP, Audit, Retention und eDiscovery im Copilot-Kontext einordnen können.
- Websuche, Teams-Copilot und Agents kontrolliert freigeben.
- Einen realistischen Pilot- und Rollout-Plan mit Betriebsmodell erstellen.

2. Architektur, Datenflüsse und das echte Risiko

Microsoft 365 Copilot verbindet große Sprachmodelle mit Unternehmensdaten über Microsoft Graph und Microsoft 365 Apps. Antworten können auf Dokumenten, E-Mails, Kalendern, Chats, Meetings und Kontakten basieren, sofern der jeweilige Benutzer darauf Zugriff hat. [1][3]

Baustein	Was passiert?	Admin-Frage
Benutzerprompt	Der Benutzer fragt Copilot in Chat, Word, Outlook, Teams oder einer anderen Oberfläche.	Dürfen Prompts sensible Daten enthalten?
Graph & Grounding	Copilot sucht Kontext in Microsoft 365-Daten, die der Benutzer sehen darf.	Sind Berechtigungen und Freigaben korrekt?
LLM-Verarbeitung	Copilot erzeugt eine Antwort auf Basis von Prompt, Kontext und Systemregeln.	Gelten Unternehmensschutz, Datenschutz und Compliance?
Antwort & Aktivität	Interaktionen können für Compliance-Zwecke gespeichert, auditiert und aufbewahrt werden.	Sind Retention, Audit und eDiscovery geregelt?

Admin-Wahrheit: Copilot ist ein Berechtigungsverstärker. Wenn ein Benutzer Zugriff auf vertrauliche Inhalte hat, kann Copilot diese Inhalte in Antworten einbeziehen. Das ist kein Berechtigungsbruch, aber es kann ein massives Governance-Problem sein. [1][5]

Risiko	Beschreibung	Admin-Reaktion
Oversharing	Zu viele Benutzer haben Zugriff auf sensible SharePoint-Sites, Teams, OneDrive-Ordner oder alte Projektablagen.	Berechtigungen prüfen, Site Access Reviews, Restricted Access Control, Gruppen bereinigen.
Veraltete Daten	Copilot verwendet alte, falsche oder nicht mehr freigegebene Dokumente als Kontext.	Retention, Archivierung, Löschkonzept und Datenqualität klären.
Externe Freigaben	Gäste, Shared Channels oder anonyme Links erzeugen unklare Zugriffsketten.	Tenant- und Site-Sharing begrenzen, Gastzugriffe prüfen, Linktypen standardisieren.
Teams-Transkripte	Meeting-Inhalte werden gespeichert und später von Copilot/Recap genutzt.	Meeting Policies, Transkriptpflicht, Aufbewahrung und Informationspflicht regeln.
Agents und Connectoren	Agents können zusätzliche Datenquellen, APIs und Aktionen einbinden.	Agent Registry, Genehmigung, Blocking, DLP, Umgebungskonzept und Datenschutzprüfung.

Websuche	Copilot kann bei erlaubter Websuche aus Prompts Suchbegriffe ableiten.	Web Search Policy und DLP-Regeln für sensitive Prompts definieren. [15]
----------	--	---

3. Voraussetzungen: Lizenzen, Apps, Identität und Rollen

Vor einem Pilotprojekt muss der Tenant technisch vorbereitet sein. Microsoft nennt unter anderem geeignete Microsoft 365-Lizenzen, Microsoft Entra ID-Konten, Exchange Online-Primärpostfächer, OneDrive für bestimmte Funktionen und passende Microsoft 365 Apps-Updatekanäle. [2][3][4]

Prüfpunkt	Empfehlung	Warum wichtig?	Status
Basislizenz	Geeignete Microsoft 365-Basislizenz und Copilot-Add-on bzw. passenden Plan prüfen.	Ohne korrekte Lizenz erscheint Copilot nicht oder nur teilweise.	☐ offen ☐ erledigt
Benutzeridentität	Benutzer mit Microsoft Entra ID verwalten; hybride Identitäten sauber synchronisieren.	Copilot arbeitet identitäts- und berechtigungsbasiert.	☐ offen ☐ erledigt
Exchange Online	Primärpostfächer in Exchange Online bereitstellen.	Copilot unterstützt keine Archive, Gruppen- oder Shared Mailboxes als primäre Basis.	☐ offen ☐ erledigt
OneDrive	OneDrive für Benutzer bereitstellen.	Einige Copilot- und Dateifunktionen benötigen OneDrive.	☐ offen ☐ erledigt
Microsoft 365 Apps	Current Channel oder Monthly Enterprise Channel verwenden.	Copilot in Desktop-Apps benötigt unterstützte Updatekanäle.	☐ offen ☐ erledigt
MFA/Conditional Access	MFA für Benutzer und Admins erzwingen; risikobasierte CA-Richtlinien prüfen.	Copilot macht Datenzugriff bequemer; Identitätsschutz muss vorher sitzen.	☐ offen ☐ erledigt
Adminrollen	Least Privilege: AI Administrator, SharePoint Admin, Teams Admin, Compliance/Purview-Rollen statt dauerhaft Global Admin.	Reduziert Missbrauch und Fehlkonfigurationen.	☐ offen ☐ erledigt

Rolle	Typische Aufgabe	Nicht sinnvoll	Hinweis
AI Administrator	Copilot-Einstellungen im Microsoft 365 Admin Center verwalten	Dauerhaft Global Admin für Tagesgeschäft	Rolle gezielt vergeben und protokollieren.
SharePoint Administrator	Sites, Freigaben, Site Access Reviews, SAM-Funktionen	Fachliche Freigabeentscheidungen allein treffen	Site Owner müssen eingebunden werden.

Teams Administrator	Meeting-, Transkript- und Copilot-Richtlinien	Datenschutzbewertung ersetzen	Betriebsrat/DSB früh einbeziehen.
Compliance Administrator	Purview, DLP, Audit, Retention, eDiscovery	Alle Daten ohne Scope einsehen	RBAC und Administrative Units prüfen.
Security Administrator	Defender, Insider Risk, Risikoalarme, Conditional Access	Alle Copilot-Fragen allein lösen	Schnittstelle zu Compliance definieren.
Datenschutzbeauftragte/r	DSFA, Informationspflicht, Rechtsgrundlage, Löschkonzept	Technische Konfiguration allein abnehmen	Gemeinsame Entscheidungsvorlage nutzen.

4. Datenschutz- und Sicherheitsprinzipien

Microsoft beschreibt für Microsoft 365 Copilot und Copilot Chat Enterprise Data Protection: Microsoft agiert nach den Produktbedingungen und dem Data Protection Addendum als Datenverarbeiter; Prompts und Antworten fallen unter diese Unternehmensschutz- und Datenschutzverpflichtungen. [1][12]

Aussage	Bewertung	Formulierung für Unternehmen
Microsoft trainiert öffentliche Modelle mit unseren Copilot-Daten.	So pauschal falsch.	Für Microsoft 365 Copilot gilt: Unternehmensdaten, Prompts und Antworten werden gemäß Microsoft 365-Verpflichtungen geschützt und nicht zur Schulung der Foundation-Modelle verwendet. [1]
Copilot sieht alles im Tenant.	Falsch.	Copilot sieht nur Inhalte, auf die der jeweilige Benutzer Zugriff hat. Das Problem sind zu breite Berechtigungen. [1][10]
Mit Copilot brauchen wir keine Datenklassifizierung mehr.	Falsch.	Labels, DLP und Berechtigungen werden wichtiger, weil KI Inhalte schneller aggregieren kann. [8][9]
Wenn Websuche an ist, können Daten in Suchanfragen einfließen.	Teilweise richtig.	Websuche muss bewusst per Policy gesteuert und bei sensiblen Prompts per DLP eingeschränkt werden. [15][9]
Agents sind nur kleine Helfer und ungefährlich.	Gefährlich falsch.	Agents können Wissen, Aktionen, Connectoren und APIs nutzen. Sie brauchen Freigabe-, Prüf- und Sperrprozesse. [13][14]

Datenschutz-Check für die Einführung

- Zweck definieren: Welche Copilot-Szenarien sind erlaubt? Schreiben, Zusammenfassen, Meeting-Analyse, Recherche, Agents, Datenabfragen?
- Rechtsgrundlage und Betriebsvereinbarung prüfen, besonders bei Teams-Transkripten, Meeting-Zusammenfassungen und Nutzungs-/Auditdaten.
- Informationspflichten erfüllen: Benutzer müssen wissen, welche Daten Copilot nutzt, was gespeichert wird und welche Regeln gelten.
- Aufbewahrung und Löschung festlegen: Prompts/Antworten, Transkripte, Meeting-Artefakte, Auditdaten und eDiscovery-Fälle.

- DSFA/Risikobewertung durchführen, wenn sensible Daten, HR-Daten, Kundendaten oder Verhaltens-/Leistungsbezug betroffen sind.
- Ausnahmen festlegen: HR, Legal, M&A, Betriebsrat, Gesundheitsdaten oder besonders vertrauliche Projekte zuerst restriktiv behandeln.

5. Datenbasis absichern: SharePoint, OneDrive, Teams und Exchange

Der wichtigste Teil der Copilot-Einführung ist nicht das Einschalten der Lizenz, sondern das Aufräumen der Datenbasis. Microsoft empfiehlt, hochriskante Sites und Inhalte zu identifizieren, Oversharing zu beheben und SharePoint Advanced Management sowie Microsoft Purview zur Vorbereitung der Datenbasis zu nutzen. [5][6][7]

Bereich	Risiko	Prüfung	Empfohlene Maßnahme	Priorität
SharePoint Sites	Jeder/Alle Mitarbeiter haben Zugriff auf vertrauliche Inhalte	Site-Berechtigungen, Gruppen, Sharing Links, externe Benutzer	Site Access Review, Gruppen bereinigen, Restricted Access Control bei kritischen Sites	Sehr hoch
OneDrive	Persönliche Freigaben enthalten Kundendaten/Verträge	Externe Links, anonyme Links, sensible Dateien	Sharing-Richtlinien, Linktypen einschränken, DLP/Labels	Hoch
Teams	Team-Mitgliedschaften geben Zugriff auf Dateien und Chats	Team Owner, Gäste, private/shared Channels	Owner-Review, Gastzugriffe prüfen, Team Lifecycle	Hoch
Exchange	Alte oder externe E-Mails werden für Zusammenfassungen genutzt	Mailbox-Typen, Aufbewahrung, externe Domains	Retention, DLP, ggf. Regeln gegen externe E-Mail als Grounding-Daten prüfen	Mittel bis hoch
Archivdaten	Alte Ablagen verschlechtern Antworten oder enthalten Altlasten	Inaktive/ownerlose Sites, alte Projektdaten	Archivieren, löschen oder von Copilot-Zugriff ausschließen	Mittel

Restricted SharePoint Search richtig einordnen: Diese Funktion kann temporär steuern, welche SharePoint-Sites in organisationsweiten Such- und Copilot-Erfahrungen erscheinen. Microsoft weist aber ausdrücklich darauf hin: Es ist keine Sicherheitsgrenze und ändert keine Berechtigungen. [6]

- Wenn eine Site wirklich geheim ist, reichen Suchbeschränkungen nicht.
- Dann müssen Berechtigungen, externe Freigaben, Gruppen, Site Access Reviews, DLP/Labels und ggf. Restricted Access Control sauber gesetzt werden.
- Site Owner müssen einbezogen werden. IT allein kann fachliche Datenklassifizierung nicht zuverlässig entscheiden.

6. Microsoft Purview: Labels, DLP, Audit, Retention und eDiscovery

Microsoft Purview ist der zentrale Baustein, um Copilot- und KI-Nutzung mit Datenklassifizierung, DLP, Audit, Aufbewahrung, eDiscovery, Insider Risk Management und Communication Compliance zu kontrollieren. [8][9][10][11]

Purview-Funktion	Wofür im Copilot-Kontext?	Admin-Entscheidung	Praxisbeispiel
Sensitivity Labels	Daten klassifizieren und Schutzregeln wie Verschlüsselung, Zugriff oder Kennzeichnung anwenden.	Labelmodell definieren: Öffentlich, Intern, Vertraulich, Streng vertraulich.	Verträge erhalten Label Vertraulich; Copilot darf nur berechtigten Benutzern Inhalte anzeigen.
DLP für Copilot	Sensible Prompts, sensitive Information Types, gelabelte Dateien/E-Mails oder Websuche begrenzen.	Custom DLP Policy mit Location Microsoft 365 Copilot and Copilot Chat.	Prompt mit Kreditkartennummer oder Ausweisnummer wird blockiert bzw. Copilot gibt keine Antwort. [9]
Audit	Copilot- und Admin-Aktivitäten nachvollziehen.	Audit aktivieren, Rollen festlegen, Such- und Exportprozess definieren.	Nachvollziehen, welche Copilot-Aktivitäten oder Admin-Änderungen stattgefunden haben. [10]
Retention	Prompts/Antworten und KI-Nachrichten aufbewahren oder löschen.	Aufbewahrungsdauer nach Datenschutz und Compliance festlegen.	Copilot-Interaktionen z. B. 180 Tage behalten und danach löschen. [11]
eDiscovery	Copilot-Interaktionen in Untersuchungen einbeziehen.	Berechtigungen, Cases und Suchprozesse definieren.	Interne Untersuchung zu sensibler Prompt-Nutzung.
Communication Compliance	Unangemessene oder riskante Inhalte in Prompts/Antworten erkennen.	Policies mit Prüfern und Eskalation definieren.	Erkennung beleidigender, diskriminierender oder riskanter Copilot-Nutzung.
Insider Risk Management	Riskante KI-Nutzung und mögliche Datenabflussmuster erkennen.	Datenschutzkonforme Rollen- und Genehmigungsprozesse festlegen.	User versucht wiederholt, sensible Kundendaten in KI-Kontexten zu verwenden.

Mindest-Set an Purview-Konfigurationen

- Sensitivity Labels definieren und veröffentlichen; besonders vertrauliche Labels testen.
- DLP-Regel für Microsoft 365 Copilot and Copilot Chat erstellen: sensible Informationstypen in Prompts blockieren oder warnen.
- DLP-Regel für gelabelte Dateien/E-Mails prüfen: besonders vertrauliche Inhalte nicht für Copilot-Zusammenfassungen verwenden lassen, sofern fachlich gewünscht. [9]
- Audit-Suche und Rollenmodell definieren; nicht jeder Admin darf alles auswerten.
- Retention Policy für Microsoft Copilot Experiences festlegen. [11]
- eDiscovery-Prozess für Copilot-Interaktionen dokumentieren.
- DSPM/DSPM for AI nutzen, um Datenrisiken und KI-Nutzungsmuster sichtbar zu machen. [8]

7. Copilot Control System und Admin-Konfigurationen

Das Copilot Control System bündelt laut Microsoft drei Säulen: Security & Governance, Management Controls sowie Measurement & Reporting. Einstellungen befinden sich vor allem im Microsoft 365 Admin Center, in Purview, im Power Platform Admin Center und in Copilot Studio. [12][13]

Konfigurationsbereich	Typischer Pfad	Empfehlung	Sicherheitsnutzen	Quelle
Copilot-Status & Lizenzen	Microsoft 365 Admin Center > Copilot	Pilotgruppe statt Big Bang	Kontrollierter Start, weniger Supportchaos	[2][13]
Benutzerzugriff	Copilot > Settings > User access	Zugriff nach Gruppen steuern	Nur vorbereitete Benutzer erhalten produktive Nutzung	[13]
Data access	Copilot > Settings > Data access	Websuche, Agents, Datenzugriff bewusst steuern	Verhindert unkontrollierte Erweiterung	[13][15]
Agents	Copilot > Settings > Data access > Agents / Integrated Apps	Nur geprüfte Agents freigeben; Agent Requests prüfen	Reduziert Daten- und Aktionsrisiken	[14]
Websuche	Cloud Policy / Copilot Web Search Policy	Für Pilot bewusst erlauben oder einschränken; DLP ergänzen	Schützt vor sensiblen Web-Suchanfragen	[15][9]
Teams Meeting Copilot	Teams Admin Center > Meetings > Meeting Policies > Recording & transcription	Policy je Zielgruppe definieren	Kontrolle über Transkriptpflicht und Meeting-Daten	[16]
Power Platform/Copilot Studio	Power Platform Admin Center / Copilot Studio	Umgebungen, DLP, Connectoren, Maker-Rollen festlegen	Verhindert Schatten-Agents und Datenabfluss	[17]
Feedback	Microsoft 365 Admin Center / Org Settings	Feedbackkanäle und Supportprozess definieren	Benutzerfeedback ohne unkontrollierte Datenweitergabe	[1]

Admin-Entscheidung Websuche: Die Websuche kann Antwortqualität verbessern, ist aber erklärungsbedürftig. Microsoft beschreibt, dass Copilot bei Websuche aus dem Prompt Suchbegriffe ableiten und an Bing Search senden kann. Daher sollte diese Funktion nicht unkommentiert tenantweit aktiviert werden. [1][15]

- Pilotentscheidung treffen: Websuche aus, eingeschränkt oder erlaubt?
- DLP-Regel: Sensible Information Types in Prompts blockieren, bevor externe Websuche genutzt wird. [9]
- Benutzerleitlinie: Keine personenbezogenen, vertraulichen oder kundenspezifischen Details in Web-Recherche-Prompts.
- Ausnahmeprozess: Fachbereiche wie Legal, HR, M&A oder Security bekommen restriktivere Policies.

8. Teams, Websuche, Copilot Chat und Agents steuern

Teams-Copilot und Transkripte

In Teams steuern Admins Copilot für Meetings und Events über Meeting Policies im Bereich Recording & transcription. Optionen umfassen u. a. Ein, Ein mit gespeichertem Transkript erforderlich, Ein mit standardmäßig gespeichertem Transkript und Aus; die Durchsetzung unterscheidet sich je nach Option. [16]

Policy-Option	Verhalten	Datenschutzbewertung	Empfehlung
Aus	Copilot ist für Meetings unter dieser Policy standardmäßig aus.	Maximal restriktiv, aber weniger Nutzen.	Für besonders vertrauliche Zielgruppen geeignet.
Ein	Organisatoren können Optionen ändern; Copilot kann nur während oder nach dem Meeting genutzt werden.	Flexibel, aber weniger kontrolliert.	Nur bei reifer Schulung und klaren Regeln.
Ein mit gespeichertem Transkript erforderlich	Copilot-Nutzung setzt gespeichertes Transkript voraus und ist stärker durchsetzbar.	Compliance-freundlicher, aber datenschutzrechtlich erklärungspflichtig.	Für regulierte Bereiche oft sauberer, wenn Retention und Information geregelt sind.
Ein mit standardmäßig gespeichertem Transkript	Transkript ist Standard, Organisator kann ändern.	Guter Kompromiss, aber nicht hart erzwungen.	Für Pilotgruppen mit Governance geeignet.

Agents und Copilot Studio

Agents erweitern Copilot über eigenes Wissen, Aktionen, Suchfunktionen, Connectors und APIs. Microsoft beschreibt für die Agent-Verwaltung im Microsoft 365 Admin Center Funktionen wie Aktivieren, Deaktivieren, Zuweisen, Blockieren oder Entfernen von Agents sowie Review-/Freigabeprozesse für angeforderte Agents. [14]

Kontrolle	Frage	Empfohlene Regel	Nachweis
Agent-Freigabe	Wer darf Agents veröffentlichen oder anfordern?	Nur definierte Maker-Gruppen; Veröffentlichung über Review-Prozess.	Agent Registry / Freigabeprotokoll
Datenzugriff	Welche Datenquellen nutzt der Agent?	Nur freigegebene Quellen; Datenschutzprüfung bei externen Systemen.	Datenquellenliste, Connector-Berechtigungen
Aktionen	Darf der Agent schreiben, senden, löschen, Tickets erstellen?	Read-only zuerst; Schreibaktionen nur mit Freigabe und Logging.	Testprotokoll, App-Berechtigungen
Connectoren	Welche Systeme werden angebunden?	DLP-Policies und Umgebungskonzept in Power Platform erzwingen.	Power Platform DLP Policy
Lebenszyklus	Wer prüft veraltete Agents?	Owner, Ablaufdatum und Review alle 90/180 Tage.	Agent-Inventar

Benutzerkommunikation	Wissen Nutzer, dass sie mit einem Agent interagieren?	Agent-Beschreibung, Zweck, Datenquellen, Grenzen sichtbar machen.	Agent-Steckbrief
-----------------------	---	---	------------------

9. Praxis-Labs für den Schulungstag

Wichtig: Die Labs sind für Testtenant oder Schulungtenant gedacht. In Produktivumgebungen nur nach Freigabe durch IT, Datenschutz und Security ausführen.

Lab 1 – Copilot-Berechtigungsrealität zeigen

Ziel: Teilnehmende sehen, dass Copilot keine neuen Rechte schafft, aber falsch gesetzte Rechte sichtbar macht.

1. Test-Site Projekt Phoenix erstellen.
2. Dokument Vertraulicher Projektplan.docx hochladen.
3. Zugriff testweise für eine zu breite Gruppe vergeben.
4. Mit Testbenutzer Copilot fragen: Fasse die wichtigsten Risiken aus Projekt Phoenix zusammen.
5. Berechtigungen korrigieren und Test wiederholen.
6. Diskussion: Welche Governance-Lücke wurde sichtbar?

Lab 2 – SharePoint- und OneDrive-Risiken priorisieren

Ziel: Admins können Sites mit hohem Risiko identifizieren und Owner Reviews planen.

7. SharePoint Admin Center öffnen.
8. Sites nach Externfreigaben, Besitzerstatus und Aktivität prüfen.
9. Data Access Governance/Site Access Review simulieren oder im Test durchführen.
10. Drei Risikokategorien vergeben: Rot, Gelb, Grün.
11. Maßnahmenliste mit Verantwortlichen erstellen.

Lab 3 – Sensitivity Labels und DLP für Copilot

Ziel: Admins konfigurieren eine Copilot-bezogene Schutzregel in Purview.

12. Purview Portal öffnen.
13. Labelmodell prüfen oder Beispiel-Label Streng vertraulich definieren.
14. DLP > Policies > Custom Policy erstellen.
15. Location Microsoft 365 Copilot and Copilot Chat aktivieren.

- Schulungsunterlage | Copilot für Admins
- 16. Regel für sensitive Information Types oder Sensitivity Labels konfigurieren.
 - 17. Mit Testprompt prüfen, ob Copilot blockiert oder eingeschränkt wird.

Lab 4 – Teams-Copilot-Meeting-Policy

Ziel: Transkript- und Copilot-Verhalten bewusst steuern.

- 18. Teams Admin Center öffnen.
- 19. Meeting Policies > Recording & transcription öffnen.
- 20. Neue Policy Copilot Pilotgruppe erstellen.
- 21. Copilot-Einstellung festlegen, z. B. Ein mit gespeichertem Transkript erforderlich.
- 22. Policy einer Testgruppe zuweisen.
- 23. Testmeeting durchführen und Verhalten dokumentieren.

Lab 5 – Agent-Governance

Ziel: Agents nicht unkontrolliert im Unternehmen wachsen lassen.

- 24. Microsoft 365 Admin Center > Copilot > Settings > Data access > Agents öffnen.
- 25. Liste vorhandener oder angeforderter Agents prüfen.
- 26. Einen Agent blockieren oder nur einer Testgruppe zuweisen.
- 27. Agent-Steckbrief erstellen: Zweck, Owner, Datenquellen, Aktionen, Datenschutzbewertung.
- 28. Freigabeprozess definieren: Antrag, Prüfung, Pilot, Veröffentlichung, Review.

Lab 6 – Audit und Retention prüfen

Ziel: Nachvollziehbarkeit für Copilot-Aktivitäten herstellen.

- 29. Purview > Audit öffnen.
- 30. Suchabfrage für Copilot-/AI-bezogene Aktivitäten vorbereiten.
- 31. Retention für Microsoft Copilot Experiences prüfen oder Konzept erstellen.
- 32. eDiscovery-Zuständigkeiten klären.
- 33. Dokumentieren, wer suchen, exportieren und auswerten darf.

10. Rollout, Betrieb und Governance

Phase	Ziel	Dauer	Kernaufgaben	Go/No-Go-Kriterium
0. Vorbereitung	Tenant bewerten	2–6 Wochen	Lizenzen, Rollen, Sharing, Purview, Pilotgruppe, Datenschutzbewertung	Kritische Oversharing-Risiken bekannt

1. Technischer Pilot	Kontrollierte Nutzung	4–8 Wochen	20–100 Benutzer, Supportkanal, Labs, Feedback, Nutzungs- und Risikoauswertung	Keine roten Datenschutz-/Security-Funde offen
2. Fachbereichsrollout	Szenarien skalieren	8–12 Wochen	Use Cases je Bereich, Trainings, Champions, Policies je Risikoklasse	Fachbereiche haben Owner und Regeln
3. Breiter Rollout	Standardbetrieb	laufend	Betriebsmodell, Monitoring, Review-Zyklen, Agent-Governance	KPIs und Kontrollprozesse funktionieren
4. Optimierung	Mehrwert und Kontrolle verbessern	laufend	Adoption, Prompt-Guides, Agents, Datenqualität, DLP-Tuning	Nutzen steigt ohne Kontrollverlust

Aufgabe	Owner	Frequenz	Ergebnis
Copilot-Lizenzreview	M365 Admin / IT-Leitung	monatlich	Ungenutzte Lizenzen umverteilen, neue Pilotnutzer aufnehmen
Oversharing Review	SharePoint Admin + Site Owner	monatlich/quartalsweise	Rote Sites bereinigt, Owner bestätigt
DLP-Tuning	Compliance Admin	monatlich	False Positives reduzieren, neue sensitive Datenarten ergänzen
Agent Review	AI Governance Board	alle 90 Tage	Agents freigegeben, gesperrt oder archiviert
Audit/eDiscovery-Test	Compliance/Security	quartalsweise	Nachweis, dass Untersuchungsprozess funktioniert
Benutzerschulung	Adoption/Training	laufend	Sichere Prompt-Regeln und Use Cases bekannt

Go-live-Mindestcheck

- Pilotgruppe definiert und geschult.
- MFA und Conditional Access aktiv und getestet.
- Kritische SharePoint-, Teams- und OneDrive-Berechtigungen geprüft.
- Externes Sharing und Linktypen bewertet und ggf. eingeschränkt.
- Sensitivity Labels veröffentlicht und mindestens für Pilotdaten getestet.
- DLP-Regeln für Copilot und Websuche geprüft.
- Teams-Copilot-Policy mit Transkriptentscheidung dokumentiert.
- Agent-Freigabeprozess aktiv.
- Audit, Retention und eDiscovery-Zuständigkeiten geklärt.

- Datenschutzinformation, Nutzungsrichtlinie und Supportprozess veröffentlicht.

11. Abschlussfragen, Vorlagen und Quellen

Abschlussfragen für die Teilnehmenden

Frage: Warum ist Copilot kein klassischer Sicherheitsbruch, aber trotzdem riskant?

Antwort: Weil Copilot bestehende Benutzerrechte respektiert, aber schlecht gepflegte Berechtigungen und zu breit freigegebene Daten schneller sichtbar macht.

Frage: Warum reicht Restricted SharePoint Search nicht als Sicherheitsmaßnahme?

Antwort: Weil es laut Microsoft keine Sicherheitsgrenze ist und keine Berechtigungen ändert; es ist eher eine temporäre Sichtbarkeitssteuerung.

Frage: Welche Purview-Funktionen sollten vor einem Copilot-Rollout mindestens betrachtet werden?

Antwort: Sensitivity Labels, DLP, Audit, Retention, eDiscovery; je nach Organisation auch Communication Compliance, Insider Risk und DSPM for AI.

Frage: Was ist bei Teams-Transkripten kritisch?

Antwort: Transkripte können sensible Meetinginhalte enthalten, werden für Copilot/Recap relevant und benötigen klare Policies, Information, Aufbewahrung und Zugriffskontrolle.

Frage: Warum brauchen Agents einen Freigabeprozess?

Antwort: Weil Agents zusätzliche Datenquellen, Aktionen, APIs und Connectoren nutzen können und dadurch mehr Risiko erzeugen als reine Chatprompts.

Frage: Was ist die beste Rollout-Strategie?

Antwort: Nicht tenantweit blind einschalten, sondern Pilotgruppe, Datenbereinigung, Policies, Schulung, Monitoring und schrittweise Skalierung.

Vorlage: kurze Copilot-Nutzungsrichtlinie

- Copilot darf zur Unterstützung bei Recherche, Zusammenfassung, Textentwurf, Meetingnachbereitung und Analyse genutzt werden, sofern keine Bereichsrichtlinie entgegensteht.
- Keine Eingabe von besonders sensiblen personenbezogenen Daten, Zugangsdaten, Geheimnissen, Gesundheitsdaten, Betriebsrats-/HR-Sonderdaten oder nicht freigegebenen Kundendaten in Prompts.
- Copilot-Antworten sind Arbeitshilfen. Fachliche, rechtliche und finanzielle Entscheidungen müssen durch zuständige Personen geprüft werden.
- Bei vertraulichen Dokumenten sind Sensitivity Labels und Freigaben zu beachten.
- Meeting-Copilot darf nur nach geltenden Meeting- und Transkriptregeln verwendet werden.
- Agents dürfen nur genutzt werden, wenn sie vom Unternehmen freigegeben sind.
- Fehlverhalten, Datenpannen oder falsche Copilot-Antworten sind über den definierten Support-/Security-Kanal zu melden.

Vorlage: Agent-Steckbrief

Feld	Eintrag
Name des Agents	
Zweck / Business Case	
Owner	
Zielgruppe	
Datenquellen	
Connectoren/APIs	
Darf lesen/schreiben/Aktionen ausführen?	
Sensitivity-Level	
DSFA erforderlich?	
DLP-Prüfung erfolgt?	
Logging/Audit	
Ablaufdatum/Reviewdatum	
Freigabe durch	

Quellen und weiterführende Microsoft-Dokumentation

Die Unterlage basiert auf öffentlich zugänglichen Microsoft-Learn-Quellen. Alle Links sollten vor produktiver Verwendung geprüft werden, da Copilot-Funktionen regelmäßig aktualisiert werden.

Quellen [1] bis [9]	Quellen [10] bis [17]
[1] Data, Privacy, and Security for Microsoft 365 Copilot – Microsoft Learn	[10] Audit logs for Copilot and AI applications – Microsoft Learn
[2] Set up Microsoft 365 Copilot and assign licenses – Microsoft Learn	[11] Learn about retention for Copilot and AI apps – Microsoft Learn
[3] App and network requirements for Microsoft 365 Copilot – Microsoft Learn	[12] Copilot Control System overview – Microsoft Learn

[4] License Options for Microsoft 365 Copilot – Microsoft Learn	[13] Copilot Control System Management Controls – Microsoft Learn
[5] Configure a secure and governed foundation for Microsoft 365 Copilot – Microsoft Learn	[14] Manage agents in the Microsoft 365 admin center – Microsoft Learn
[6] Restricted SharePoint Search – Microsoft Learn	[15] Data, privacy, and security for web search in Microsoft 365 Copilot and Copilot Chat – Microsoft Learn
[7] SharePoint Advanced Management overview – Microsoft Learn	[16] Manage Microsoft 365 Copilot in Teams meetings and events – Microsoft Learn
[8] Use Microsoft Purview to manage data security & compliance for Microsoft 365 Copilot & Copilot Chat – Microsoft Learn	[17] Copilot Studio security and governance – Microsoft Learn
[9] DLP for Microsoft 365 Copilot and Copilot Chat – Microsoft Learn	